Instituto Tecnológico de Costa Rica
Escuela de Ingeniería en Computadores
CE-1115 Seguridad de la Información

Proyecto · Parte 1 · Diseño del control de acceso

Documento de arquitectura del sistema

Componentes, tecnologías y decisiones de seguridad

Entregable 4 de 5

Cliente

Verdeazul Carbono S.A.

Certificación de captura de carbono · Pérez Zeledón, Costa Rica

Grupo 6

Integrante	Carné
Randall Bryan Bolaños López	2019043784
Javier Tenorio Cervantes	2020065308
Julio Varela Venegas	2019008041
Axel Flores Lara	2021453573

Prof. MSc. Andrés Vargas Rivera

Semestre II, 2026

Fecha de entrega: 15 de octubre de 2026

Índice

1. Qué se va a construir **1**

2. Arquitectura general **1**

2.1. Componentes 1

2.2. Fronteras de confianza 2

2.3. Flujo de una petición autenticada 3

3. Selección de tecnologías **3**

4. Decisiones de seguridad de la implementación **6**

4.1. Dónde vive la decisión de autorización 6

4.2. Cómo se implementan las celdas condicionadas 7

4.3. Almacenamiento de credenciales 8

4.4. Gestión de sesión 8

4.5. Diseño de la bitácora 8

4.6. Gestión de secretos 9

4.7. Fechas de medición y de registro 9

4.8. Autenticidad y estado del certificado 9

4.9. Riesgos residuales 10

5. Hospedaje y operación **11**

6. Criterios de aceptación de seguridad **12**

Anexo A. Diagramas **13**

Anexo B. Capacidad y operación **16**

Anexo C. Respuestas del cliente y supuestos declarados **17**

Referencias **17**

1 Qué se va a construir

Este documento es para el equipo que va a construir la plataforma. Dice de qué piezas se compone, con qué tecnologías se hace cada una y cómo se llevan al sistema las reglas de la matriz de control de acceso (Entregable 3). Cada elección se justifica desde la seguridad.

La plataforma es una aplicación web. Técnicos, verificadores, supervisores, gerencia, administrador, dueños y auditores la usan desde un navegador; no hay un programa que instalar ni, en esta etapa, una aplicación sin conexión. [minuta P-22] Corre en un solo servidor virtual, contratado a un proveedor externo y operado por personal que Verdeazul designe (sección 5), en contenedores sin privilegios de administrador. [minuta P-23] Toda petición pasa por un único punto de decisión antes de tocar un dato.

Decisión	Elección	Versión	Licencia
Lenguaje	Python	3.14	PSF
Framework	Django	5.2 LTS	BSD de 3 cláusulas
Base de datos	PostgreSQL con PostGIS	18 y 3.6	PostgreSQL y GPL 2
Mecanismo de sesión	Sesión de servidor con cookie opaca	la de Django 5.2	BSD de 3 cláusulas
Motor de autorización	Open Policy Agent (OPA)	1.21	Apache 2.0
Contenedores	Podman sin privilegios, sobre AlmaLinux	5.8 sobre 10.2	Apache 2.0 y GPL 2
Proxy y TLS	Caddy	2.11	Apache 2.0
Secretos y sello	OpenBao	2.7	MPL 2.0

Todo es software libre, como pide la carta. La condición no fue un trámite: dos opciones conocidas se descartaron por su licencia (sección 3).

Supuestos de capacidad. El cliente no tiene cifras y pidió que el diseño no dependa de cantidades fijas. [minuta P-02] Nada en el modelo crece con el catálogo: los roles son siete con cualquier número de fincas y los umbrales son parámetros por rol. Solo el tamaño del servidor exigió suponer una carga, declarada en el Anexo B.1: hasta 100 cuentas internas y 2 000 fincas caben con margen en un servidor virtual de 4 núcleos y 16 GB, que se amplía sin migrar.

2 Arquitectura general

2.1 Componentes

El sistema tiene nueve piezas, agrupadas en cuatro zonas de confianza. El diagrama es la figura 1, en el Anexo A.1; la tabla dice qué hace cada pieza.

Componente	Qué hace
Proxy (Caddy)	Única puerta de entrada. Termina la conexión cifrada, obliga a usar HTTPS y limita el tamaño y el ritmo de las peticiones.
Aplicación (Django)	Identifica al usuario, valida lo que llega, reúne los hechos que la decisión necesita, pregunta al motor y ejecuta solo lo concedido. Contiene las máquinas de estado de mediciones, períodos y enmiendas.
Motor de decisión (OPA)	Responde «conceder», «conceder con restricción» o «denegar» a cada petición. Su política es la matriz: los roles, las reglas C1 a C20 y los controles H1 a H4.
Servicio de emisión	Proceso sin usuario humano (la fila SIS de la matriz). Emite y revoca certificados y los sella con una llave que no puede leer.
Comprobación pública	Ruta de solo lectura y sin sesión (la fila PUB). Recibe el código de un certificado y responde si es auténtico y cuál es su estado, desde una vista que solo contiene esos campos. [minuta P-04]
Trabajos programados	Calculan las alertas, verifican la cadena de la bitácora, envían su huella diaria al testigo externo, hacen vencer cuentas, habilitaciones y asignaciones temporales, y generan los reportes de revisión.
Base de datos (PostgreSQL)	Guarda los datos del negocio, las sesiones y la bitácora. Vuelve a aplicar, como segundo candado, las reglas que se pueden expresar como restricción.
Bóveda (OpenBao)	Guarda las contraseñas de servicio y las llaves. Firma los certificados sin entregar la llave.
Testigo externo	Un servicio de sello de tiempo y el buzón del auditor. Reciben cada día una huella de la bitácora; no reciben datos.

2.2 Fronteras de confianza

La regla general es la de la clase 14: se supone hostil todo lo que está fuera de la propia zona. Cada frontera dice qué no se da por bueno al cruzarla y dónde se valida.

Id.	Frontera	Qué no se da por bueno	Dónde y cómo se valida
F1	Internet y el dispositivo, hacia el proxy	La red, el equipo y todo lo que envía el navegador: identificadores en la dirección, campos ocultos, cabeceras, cookies y archivos. La empresa no administra todos los equipos de campo. [minuta P-22]	En el proxy: solo TLS 1.3 o 1.2, cabecera HSTS, límite de tamaño y de ritmo. Nada se interpreta todavía.
F2	Proxy, hacia la aplicación	El contenido de la petición. Que venga por HTTPS no la hace legítima.	En la aplicación: sesión válida, marca contra peticiones falsificadas (CSRF), tipo y rango de cada campo. Es la validación principal de entrada.
F3	Aplicación, hacia el motor	Los hechos sobre los que se decide.	La aplicación los toma de la base de datos, nunca de la petición. El motor solo escucha en la red interna. Si no responde, la aplicación deniega.
F4	Aplicación, hacia la base de datos	La propia aplicación: puede tener un error.	La base aplica restricciones, seguridad por fila y una bitácora en la que la aplicación solo puede insertar. La aplicación no es dueña de las tablas.

Id.	Frontera	Qué no se da por bueno	Dónde y cómo se valida
F5	Servidor, hacia el exterior	El proveedor de hospedaje, el de respaldos y, en sentido contrario, quien administra el servidor.	Los respaldos salen cifrados. El testigo recibe solo huellas, y con ellas se detecta cualquier cambio hecho desde dentro del servidor.

El operador de plataforma queda fuera de la zona de confianza de los datos. Tiene acceso al servidor, no a la aplicación, y lo que haga directamente sobre la base queda en un registro que sale del servidor (sección 4.5). Es personal que Verdeazul designa, no un especialista: la sección 5 dice qué tareas le tocan. [minuta P-23]

2.3 Flujo de una petición autenticada

Ejemplo: un verificador aprueba la medición 8841. El diagrama de secuencia está en el Anexo A.2.

1. El navegador envía la petición por HTTPS. El proxy la recibe y la pasa a la aplicación.
2. La aplicación busca la sesión que indica la cookie. Si no existe o venció, responde que hay que iniciar sesión y termina.
3. Valida la marca contra peticiones falsificadas (CSRF) y la forma de los datos.
4. Lee de la base los hechos: rol del sujeto, estado de la medición y de su período, autores de todas sus versiones, vínculos declarados y el historial reciente del sujeto.
5. **Punto de decisión.** Entrega al motor el sujeto, la acción, el objeto y esos hechos. El motor evalúa las tres capas (rol, condiciones, historial) y devuelve la decisión con el identificador de la regla que la determinó.
6. Si la decisión es *denegar*, la aplicación lo registra en la bitácora y responde sin revelar si el objeto existe. Si es *conceder con restricción*, pide el segundo factor y el motivo.
7. Si es *conceder*, abre una transacción: cambia el estado solo si la medición sigue ENVIADA, escribe el registro de bitácora y confirma las dos cosas juntas.
8. La base aplica sus propias restricciones. Si alguna falla, la transacción entera se deshace.
9. El servicio de emisión toma la medición aprobada y emite el certificado bajo la regla C4.

> La decisión de autorización se toma **en el servidor, en un solo lugar (paso 5), antes de leer o cambiar el dato**, y en cada petición. Los pasos 7 y 8 son candados independientes del mismo criterio.

3 Selección de tecnologías

Para cada decisión se indican los cinco puntos que pide el enunciado: qué se eligió y en qué versión, qué alternativas se descartaron, qué aporta a la seguridad, qué limitaciones tiene y cómo se compensan, y con qué herramientas se analiza.

Lenguaje: Python 3.14	
Elección	Python 3.14, con correcciones de seguridad hasta octubre de 2030.

Alternativas	*Java con Spring*: maduro y de tipado estático, pero más costoso de desarrollar y operar para un equipo pequeño. *JavaScript con Node*: cada proyecto arrastra cientos de paquetes de terceros, y cada uno es una vía de ataque a la cadena de suministro. *Go*: binarios simples, pero sin un marco que traiga las protecciones integradas, lo que obliga a escribir a mano más código de seguridad.
Aporta	Gestión automática de memoria: el código propio no produce desbordamientos. Tipado fuerte, sin conversiones implícitas peligrosas. Biblioteca estándar con generación de secretos y comparación en tiempo constante. Es el lenguaje con más oferta de personal en el país, y eso importa para mantener el sistema diez años.
Limitaciones	Los errores de tipo aparecen al ejecutar: se compensan con anotaciones de tipo comprobadas en cada integración. Los paquetes de PyPI pueden ser suplantados: se fijan versión y huella de cada dependencia. Funciones como `eval` o `pickle` sobre datos externos ejecutan código: se prohíben por regla de análisis.
Herramientas	Bandit y Ruff (análisis estático de seguridad), mypy (tipos), pip-audit (vulnerabilidades conocidas en dependencias).

Framework: Django 5.2 LTS

Elección	Django 5.2 LTS, con soporte de seguridad hasta abril de 2028. Se planifica la migración a la 6.2 LTS, prevista para abril de 2027.
Alternativas	*Flask* y *FastAPI*: son marcos mínimos; la sesión, la protección contra peticiones falsificadas, el acceso a datos y la autenticación se arman con piezas sueltas, y cada pieza es una oportunidad de error. *Spring*, *Laravel* y *Rails*: equivalentes, descartados por el lenguaje.
Aporta	De forma nativa: consultas parametrizadas en su capa de datos, que previenen la inyección SQL; plantillas que escapan la salida por omisión, contra la inyección de *scripts*; protección contra peticiones falsificadas activada por omisión; cabeceras de seguridad; sesiones de servidor; marco de contraseñas con Argon2; y una orden, `check --deploy`, que audita la configuración de producción.
Limitaciones	Sus permisos son por tipo de objeto, no por objeto: usados solos permiten cambiar un identificador y ver lo ajeno. Por eso la decisión se saca a OPA y se repite en la base. Su sitio de administración edita cualquier tabla saltándose las reglas: **no se instala**. Las consultas en SQL directo reabren la inyección: se prohíben por análisis estático. No trae segundo factor: se agrega con django-allauth.
Herramientas	`check --deploy`, OWASP ZAP (análisis dinámico), sqlmap (inyección) y las pruebas automáticas de la matriz.

Base de datos: PostgreSQL 18 con PostGIS 3.6

Elección	PostgreSQL 18, con soporte hasta noviembre de 2030, y PostGIS 3.6 para la geometría de las parcelas.
Alternativas	*MariaDB*: no tiene seguridad por fila, de modo que el aislamiento entre dueños dependería solo de la aplicación. *SQLite*: sin roles ni acceso concurrente por red. *MongoDB*: su licencia SSPL no está reconocida como software libre, y no ofrece las restricciones que impiden la doble emisión. *Un libro mayor tipo cadena de bloques*: resuelve la desconfianza entre varias organizaciones, que aquí no existe; la inalterabilidad necesaria se logra con mucho menos (sección 4.5).
Aporta	Seguridad por fila: el alcance del técnico (C1) y el «solo lo suyo» del dueño (C5) se aplican también en la base. Restricciones que hacen imposible la doble emisión: un índice único de certificado vigente por parcela y período, y con PostGIS el rechazo de parcelas traslapadas. Privilegios por tabla y por operación: la aplicación puede insertar en la bitácora, pero no modificarla. Transacciones: la acción y su registro se confirman juntos. Sumas de verificación de datos activas por omisión desde la versión 18.

Limitaciones	El superusuario se salta todo lo anterior: no se usa en operación, su uso es una emergencia registrada y la bitácora se ancla fuera del servidor. No cifra los datos en reposo: se cifran el disco y los respaldos. La misma regla vive en OPA y en la base, y podrían divergir: los casos T-01 a T-37 se ejecutan contra ambas.
Herramientas	pgAudit (registro de sentencias, incluidas las del superusuario), pgTAP (pruebas de restricciones y de seguridad por fila) y la guía de configuración segura del CIS.

Mecanismo de sesión: sesión de servidor con cookie opaca

Elección	La sesión se guarda en el servidor, en una tabla de PostgreSQL. El navegador solo recibe una cookie con un identificador aleatorio que no significa nada por sí mismo.
Alternativas	*Tokens JWT sin estado*: un *token* firmado vale hasta que vence, así que no se puede revocar en el acto al dar de baja a alguien o cambiarle el rol, salvo que se vuelva a guardar estado en el servidor. *Sesión guardada en la propia cookie*: mismo problema. *Sesión en una memoria caché aparte*: otro componente que operar, innecesario con la carga supuesta.
Aporta	Revocación inmediata: basta borrar la fila. El rol no viaja en el navegador; se lee de la base en cada decisión, así que un cambio de privilegios rige desde la siguiente petición. La cookie es inaccesible para los *scripts* de la página, solo viaja por HTTPS y no se envía desde otros sitios. Al iniciar sesión se genera un identificador nuevo.
Limitaciones	La cookie es un pase al portador: quien la copie entra, como mostró Firesheep. Se compensa con cifrado en toda la sesión, vida corta (30 minutos de inactividad, 12 horas como máximo) y reautenticación en las decisiones. No se ata a la dirección de red, porque en el teléfono cambia; un cambio brusco sí es una señal para los controles de historial.
Herramientas	OWASP ZAP (pruebas de gestión de sesión), testssl.sh (configuración de TLS) y Mozilla HTTP Observatory (cabeceras y cookies).

Motor de autorización: Open Policy Agent 1.21

Elección	OPA 1.21 como punto de decisión, en un contenedor junto a la aplicación. La política se escribe como texto y es la matriz transcrita: una tabla de rol, objeto y verbo, y una regla por cada condición, con su mismo identificador.
Alternativas	*Permisos de Django con comprobaciones en cada pantalla*: la decisión queda repartida por todo el código y basta olvidar una para abrir un hueco. *Casbin*: es una biblioteca dentro de la aplicación; las condiciones de historial terminarían escritas como código, sin registro propio de decisiones. *Cedar*: lenguaje muy legible, pero su integración con Python es reciente y la mantiene la comunidad. *Keycloak*: ata la autorización a un proveedor de identidad que una sola aplicación no necesita.
Aporta	Un solo lugar donde vive la decisión. Niega por omisión. La política es un texto versionado que se puede revisar, firmar y enseñar al auditor. Trae un marco de pruebas, con lo que la matriz se verifica celda por celda de forma automática. Registra cada decisión con la regla que la determinó.
Limitaciones	Si no responde, no hay decisión: la aplicación deniega y se vigila su disponibilidad. No conoce el historial; decide con los hechos que recibe: un único módulo los arma, siempre desde la base. Responde sí o no a una petición, no filtra listados: de eso se encarga la seguridad por fila. Su lenguaje, Rego, es nuevo para el equipo: se escribe una regla por condición y nada más.
Herramientas	`opa test` con medición de cobertura, `opa check` en modo estricto y Regal (analizador de políticas).

Contenedores: Podman 5.8 sin privilegios, sobre AlmaLinux 10

Elección	Podman 5.8, el que distribuye AlmaLinux 10.2, con contenedores sin privilegios administrados por el propio sistema. AlmaLinux 10 recibe parches de seguridad hasta 2035, lo que cubre los diez años de trazabilidad.

Alternativas	*Docker Engine*: por omisión depende de un servicio que corre como administrador, y quien controla ese servicio controla el servidor. *Docker Desktop*: no es software libre. *Kubernetes*: pensado para muchos servidores; aquí solo agrega superficie y exige un conocimiento especializado que la empresa no tiene. [minuta P-23] *Sin contenedores*: las dependencias se mezclan con el sistema y es más difícil reproducir y parchar.
Aporta	No hay servicio con privilegios. Cada contenedor corre bajo un usuario común: salir del contenedor no da el control del servidor. SELinux, en modo obligatorio, confina cada contenedor: es el control de acceso obligatorio (MAC) que se descartó para la aplicación, usado donde sí corresponde. Sistema de archivos de solo lectura. Redes internas: solo el proxy es alcanzable desde fuera y la base no publica ningún puerto.
Limitaciones	Todos los contenedores comparten el núcleo del servidor: se aplican parches automáticos. Las imágenes de terceros traen vulnerabilidades: se usan imágenes propias mínimas, fijadas por huella y analizadas. Un solo servidor es un punto único de falla: se compensa con respaldos y una restauración probada. [supuesto P-24]
Herramientas	Trivy o Grype (vulnerabilidades en imágenes), Syft (inventario de componentes) y OpenSCAP (endurecimiento del sistema).

Componentes de apoyo.

Función	Elección	Razón de seguridad y alternativa descartada
Proxy y TLS	Caddy 2.11	HTTPS automático con certificados de Let's Encrypt y valores seguros por omisión. Nginx exige configurar TLS a mano.
Secretos y sello	OpenBao 2.7	Firma sin entregar la llave y registra cada uso. HashiCorp Vault se descartó porque desde 2023 su licencia (BUSL) no es de software libre.
Segundo factor	django-allauth	Llaves de acceso (WebAuthn) del propio dispositivo y códigos temporales, sin costo de hardware. Admite llaves físicas FIDO2 para las cuentas privilegiadas. El SMS se descarta (POL-AU-05). [minuta P-23]
Resumen de contraseñas	Argon2id	Ver la sección 4.3.
Respaldos	Copia base y archivo continuo de PostgreSQL, cifrados con *age*	Se cifran antes de salir del servidor, con una llave que el proveedor de almacenamiento no tiene.

4 Decisiones de seguridad de la implementación

4.1 Dónde vive la decisión de autorización

Vive en el motor de decisión, en el servidor. La aplicación tiene un único módulo de cumplimiento por el que pasa toda ruta; una ruta que no declare qué acción y qué objeto protege no arranca, y eso se comprueba con una prueba automática que recorre todas las rutas.

Qué pasa si el control está solo en la interfaz. Supóngase que la pantalla del técnico simplemente no muestra el botón «Aprobar». El técnico, con su sesión válida, envía a mano la petición de aprobar su propia medición. Si el servidor no decide, la ejecuta, y con eso un técnico mide y aprueba. Es el mismo error de la clase 13: cambiar un número en la dirección y ver el certificado de otro dueño. En este diseño la interfaz también le pregunta al motor qué botones mostrar, pero solo por comodidad. Lo que protege es el paso 5 de la sección 2.3, y detrás de él la base de datos.

Los identificadores de los objetos no son consecutivos, para que no se puedan recorrer. Es higiene, no control: el control es comprobar el permiso sobre cada objeto.

4.2 Cómo se implementan las celdas condicionadas

Cada regla se evalúa dos veces: antes de leer o cambiar el dato y, cuando hay un cambio, otra vez dentro de la transacción que lo aplica. Así dos verificadores que aprueban a la vez, o un período que cierra mientras alguien edita, no dejan el sistema en un estado que las reglas prohíben.

Regla	Qué hay que almacenar	Cuándo se evalúa	Segundo candado en la base
C1, C19	Asignaciones: técnico, finca, período, tipo, motivo y vigencia.	En toda petición sobre una finca; al asignar.	Seguridad por fila según la asignación vigente.
C2, C14	Estado de cada medición y período; autor de cada versión; fecha de medición y de registro.	Al crear, modificar o enviar; al abrir y cerrar.	Un disparador rechaza cambios con el período cerrado y fechas fuera del período.
C3, C8, C10	Una fila por versión de medición y por paso de enmienda, con su autor; si la enmienda es material.	Al aprobar, revisar o autorizar.	Restricción: quien decide no figura en un paso anterior.
C4	Certificado con parcela, período, estado y enlace al que reemplaza.	Al emitir y al autorizar una enmienda.	Índice único de vigente por parcela y período; revocar y emitir en una transacción.
C5	Titular de cada finca y cuentas que lo representan.	En toda lectura de un dueño.	Seguridad por fila según el titular.
C6, C18	Vigencia de la cuenta; registro y huella de cada paquete exportado.	Al iniciar sesión, en cada petición y al exportar.	Conexión de solo lectura para el auditor.
C7, C9	Las filas de autoría y dictamen de C3; fecha de la solicitud.	Al solicitar y al corregir.	Restricción de fecha.
C11	Geometría de cada parcela; estado propuesto o aprobado.	Al proponer y al aprobar.	Restricción espacial que impide el traslape.
C12	Propuesta de rol, quién propone y quién aprueba; fin de una habilitación.	Al aprobar.	Restricción de roles por persona e identidad única.
C13, C15	Titular de la cuenta; sujeto de cada alerta y su supervisor.	Al cambiar credenciales; al resolver.	No aplica.
C16	Fecha del último certificado ligado al titular.	Al suprimir datos personales.	Impide borrar un titular con certificados en plazo.
C17	Declaración de vínculos: persona, titular y fechas.	En toda acción sobre una finca que no sea leer.	No aplica: vive en el motor.
C20	Código de cada certificado; vista con sello, estado, toneladas y reemplazo.	En cada consulta pública.	La ruta pública solo lee esa vista.
H1, H3	Un evento por lectura; las fincas que cada sujeto vio en 90 días; los umbrales por rol.	Antes de entregar el detalle de una finca.	No aplica: vive en el motor.
H2	Jornada de cada rol.	En cada acción de decisión.	No aplica.

Los contadores de H1 y H3 se calculan con una consulta sobre una ventana de tiempo. Con la carga supuesta no hace falta un sistema aparte de procesamiento de eventos.

4.3 Almacenamiento de credenciales

Contraseñas. Se guarda solo un resumen calculado con **Argon2id**, con una sal aleatoria por usuario. La razón es la de Morris y Thompson (1979), vista en clase: quien roba la base no debe poder probar millones de contraseñas por segundo. Argon2id es lento a propósito y además exige mucha memoria, lo que anula la ventaja de las tarjetas gráficas; bcrypt no exige memoria y PBKDF2, el valor por omisión de Django, tampoco. Parámetros iniciales: los de Django (100 MiB de memoria, dos iteraciones), por encima del mínimo que recomienda OWASP (19 MiB). El costo se sube con los años sin obligar a nadie a cambiar su contraseña.

Segundo factor. De una llave de acceso solo se guarda la llave pública: no hay nada que robar. La semilla de los códigos temporales se guarda cifrada con una llave que vive en la bóveda. Los códigos de recuperación se guardan resumidos, como las contraseñas.

Lo que nunca se hace. Guardar contraseñas en claro o con cifrado reversible, escribirlas en un registro o enviarlas por correo.

4.4 Gestión de sesión

- **Entre peticiones** el usuario se identifica por la cookie de sesión. La aplicación la busca en la tabla de sesiones y de ahí obtiene quién es; el rol se lee de la base en ese momento.
- **Al iniciar sesión** se genera un identificador nuevo, para que nadie pueda fijar uno de antemano.
- **Al cerrar sesión** la fila se borra. La cookie que quede en el navegador ya no sirve.
- **Al cambiar de privilegios** (rol, asignaciones, contraseña o baja) se borran todas las sesiones de esa persona. Su siguiente petición exige iniciar sesión, y entra ya con los permisos nuevos.
- **Para las decisiones** la sesión guarda cuándo se presentó por última vez el segundo factor. Si pasaron más de cinco minutos, se pide de nuevo.
- **Vencimiento**: 30 minutos sin actividad o 12 horas en total, lo que ocurra primero.

4.5 Diseño de la bitácora

Qué eventos. Los de la política POL-BT-01: autenticación, cambios, consultas de datos sensibles, exportaciones, administración, y toda decisión denegada o con restricción.

Con qué campos. Instante, según el reloj del servidor; cuenta y rol; acción; tipo e identificador del objeto y su versión; resultado y regla que lo decidió; origen (dirección, sesión); huella del valor anterior y del nuevo; huella del registro anterior; y huella propia.

Cómo se protege de quien tiene permiso de escritura. El permiso de escritura es, en realidad, solo de inserción, y cuatro mecanismos se apoyan entre sí.

1. **Solo insertar.** La cuenta con que la aplicación se conecta a la base puede agregar registros, no modificarlos ni borrarlos. Un disparador rechaza cualquier intento.
2. **Cadena de huellas.** Cada registro incluye la huella SHA-256 del anterior. Cambiar o quitar uno rompe la cadena desde ese punto (Schneier y Kelsey, 1999).
3. **Testigo externo.** Una vez al día la última huella sale del servidor: recibe un sello de tiempo (RFC 3161) y se envía al buzón de la Gerencia y del auditor. Ni siquiera quien tenga control total de la

base puede reescribir el pasado sin que deje de coincidir con lo que ya está afuera.

4. **Misma transacción.** La acción y su registro se confirman juntos. No puede haber acción sin registro ni registro de algo que no ocurrió.

Conservación. La que fija la política POL-BT-04: diez años para cambios y decisiones, que es la trazabilidad que el cliente debe poder reconstruir **[minuta P-18]**, y dos para consultas. [supuesto P-19] La tabla se divide por mes, de modo que lo antiguo se archiva sin romper la cadena.

Un trabajo diario recalcula la cadena, y el auditor puede hacerlo por su cuenta. Lo que el operador ejecute directamente en la base queda en un registro aparte que se envía fuera del servidor.

4.6 Gestión de secretos

Cuáles son. Las contraseñas con que la aplicación y los trabajos se conectan a la base; la llave que sella los certificados; la llave que cifra las semillas del segundo factor; la llave secreta del framework; la credencial del correo saliente; y las llaves de cifrado de los respaldos.

Dónde viven. En la bóveda. Cada componente se autentica ante ella al arrancar y recibe solo los secretos que le corresponden, que mantiene en memoria. La llave de sello nunca sale: el servicio de emisión le pide a la bóveda que firme. Es la raíz de confianza de todos los certificados, y la clase 14 mostró qué ocurre cuando una raíz así se compromete.

Por qué no en el código. El repositorio guarda su historia para siempre y lo lee todo el que desarrolla; las imágenes de los contenedores se copian; y cambiar un secreto obligaría a publicar una versión nueva. Un secreto en el código deja de ser secreto el día que se escribe. Cada cambio al repositorio se analiza con gitleaks para detectar secretos antes de aceptarlo.

Quién abre la bóveda. La llave que la abre se divide en tres partes, y hacen falta dos. Las custodian la Gerencia General, la Gerencia de Certificación y el operador. Nadie la abre solo.

4.7 Fechas de medición y de registro

El cliente no pide una aplicación sin conexión, pero sí contemplar cómo trabaja el campo: la señal no siempre alcanza y algunos técnicos registran después de la visita. **[minuta P-22]**

- **Dos fechas por medición.** La de registro la pone el servidor. La de medición la declara el técnico, y solo se acepta si cae dentro del período y de su asignación y no es posterior a la de registro (C2). El verificador ve las dos; más de cinco días hábiles entre ambas pide un motivo.
- **Dos fechas por período.** El fin de medición y, unos días después, el cierre de registro: lo medido el último día en una finca sin señal todavía se registra. Después, solo por enmienda.
- **La hoja de campo es evidencia.** Su fotografía se puede adjuntar a la medición; el sistema guarda su huella.

4.8 Autenticidad y estado del certificado

El cliente quiere poder demostrar que un certificado es auténtico, cuál es su estado y quién autorizó su emisión, y pidió valorar si hace falta una firma digital. **[minuta P-04]**

Alternativa	Qué demuestra	Qué no	Costo y operación
Firma digital certificada de cada verificador (Ley 8454)	Autenticidad y autoría, con presunción legal.	El estado: un documento firmado sigue pareciendo válido después de revocado.	Certificado y dispositivo por persona, y su renovación.
Sello electrónico de la empresa, con llave en la bóveda	Autenticidad del contenido, incluido el nombre de quien aprobó.	El estado. No tiene la presunción legal de la firma certificada.	Ninguno adicional.
Comprobación en línea por código	El estado de hoy y el enlace con el reemplazo.	Por sí sola, que el documento no fue alterado.	Una ruta pública de solo lectura.

> **Decisión.** No se exige firma digital certificada a cada verificador. El certificado lleva el **sello electrónico de la empresa** y un código; el estado se demuestra con la **comprobación en línea**; y quién autorizó, con la aprobación personal con segundo factor, que queda en la bitácora y dentro del contenido sellado. La firma personal no demuestra el estado, que es lo que importa cuando un certificado se revoca. Si Verdeazul quiere presunción legal para el sello, puede cambiar después la llave propia por un certificado de sello electrónico de persona jurídica (Ley 8454): cambia la custodia de la llave, no el flujo.

4.9 Riesgos residuales

Id.	Qué queda sin cubrir	Por qué se acepta y qué lo acota
RR-1	Colusión entre un técnico y un verificador.	Impedirla exigiría una tercera persona en cada certificado. La acotan la rotación, el indicador de parejas repetidas y la auditoría externa.
RR-2	Una medición falsa desde el origen.	El sistema no ve el árbol. La acotan la verificación independiente y la validación de rangos.
RR-3	Extracción lenta, por debajo de los umbrales, o con fotografías de la pantalla.	Los controles de historial la vuelven lenta y visible, no imposible. La confidencialidad firmada da la vía legal.
RR-4	Un equipo de usuario infectado, que actúa con su sesión. La empresa no administra todos los equipos. **[minuta P-22]**	El servidor no lo distingue de la persona. Lo acotan la reautenticación en las decisiones, la llave de acceso y que un técnico solo alcanza sus fincas asignadas.
RR-5	El operador puede detener el servicio o destruir datos.	Se detecta y se recupera, no se impide. La acotan los respaldos fuera del sitio y el testigo externo.
RR-6	Un solo servidor.	La redundancia duplica el costo y la operación. Se acepta un día de interrupción; no se acepta perder datos: el archivo continuo permite restaurar en otro servidor. [supuesto P-24]
RR-7	Sin hardware de seguridad dedicado para la llave de sello ni, si no se compran llaves físicas, para las cuentas privilegiadas.	No hay presupuesto comprometido. **[minuta P-23]** Lo acotan la bóveda, el registro de cada firma y la rotación anual.
RR-8	La fecha de medición es declarada.	Sin aplicación sin conexión, el sistema no puede probar cuándo se midió ni evitar un error al transcribir. **[minuta P-22]** Lo acotan las dos fechas, su validación y la verificación independiente.

Id.	Qué queda sin cubrir	Por qué se acepta y qué lo acota
RR-9	El histórico migrado de las hojas de cálculo.	No se le puede dar la trazabilidad que nunca tuvo. Queda congelado, con su huella, y marcado como histórico. [supuesto P-26]
RR-10	La misma regla en dos lugares, el motor y la base.	Es el precio de tener dos candados. Las pruebas T-01 a T-37 se ejecutan contra ambos.
RR-11	Vínculos no declarados entre un empleado y un dueño.	No existe un registro que los descarte. **[minuta P-15]** Lo acotan que ningún paso lo completa una sola persona, los indicadores de parejas repetidas y la sanción por omitir.
RR-12	El proveedor de hospedaje tiene acceso físico al servidor.	Es el precio de no operar un cuarto de servidores. **[minuta P-23]** Lo acotan el contrato, los respaldos cifrados en otro proveedor y el testigo externo.
RR-13	La aprobación no lleva firma digital certificada.	Ante un tercero, la autoría descansa en la bitácora y el sello, sin presunción legal. **[minuta P-04]** Puede agregarse después sin rediseñar.

5 Hospedaje y operación

El cliente no ha decidido dónde hospedar la plataforma, no tiene un equipo de ciberseguridad y pidió una recomendación fundamentada en seguridad, mantenimiento, disponibilidad y costo, que no dependa de especialistas para lo cotidiano. **[minuta P-23]**

Criterio	Servidor propio en la oficina	Servidor virtual contratado	Servicios administrados
Seguridad	La seguridad física, eléctrica y de red queda a cargo de la empresa.	El proveedor pone el centro de datos; Verdeazul controla el sistema y sus llaves. Es un tercero más (RR-12).	La base y las llaves quedan en cuentas del proveedor.
Mantenimiento	Equipo, repuestos, energía y enlace, además del sistema.	Solo el sistema, que se parcha solo.	El menor, pero con servicios que no son software libre.
Disponibilidad	La de la electricidad y el enlace de una oficina rural.	La del centro de datos; se restaura en horas.	La más alta.
Costo	Inversión inicial y reposición cada pocos años.	Pago mensual bajo y predecible.	El mayor y el menos predecible.

> **Recomendación.** Un **servidor virtual contratado**, con los respaldos cifrados en un proveedor distinto. Da la disponibilidad y la seguridad física que una oficina no puede dar, no exige comprar equipo, crece con la empresa y conserva el diseño en software libre. De preferencia con centro de datos en Costa Rica, para que los datos personales no salgan del país. Los montos deben cotizarse.

Quién opera. Personal que la empresa designe, sin ser especialista. Lo cotidiano está automatizado (respaldos, parches, verificación de la bitácora, vencimientos): el operador lee un aviso diario. Lo periódico tiene guía escrita: el reinicio mensual, que pide dos custodios para abrir la bóveda, y la prueba semestral de restauración. Lo extraordinario lo atiende soporte especializado por contrato (Anexo B.2). La bóveda es la pieza que más pide; si Verdeazul prefiere menos operación, los secretos pueden ir cifrados en el propio servidor, a costa del registro de cada firma (sube RR-7).

6 Criterios de aceptación de seguridad

El sistema no entra en operación hasta cumplir estos criterios. Están escritos para que el equipo que construye sepa cuándo terminó, sin tener que preguntar.

N.°	Criterio	Cómo se comprueba
1	La matriz se cumple celda por celda.	Los casos T-01 a T-37 y una prueba por cada celda sin acceso pasan contra el motor y contra la base.
2	Ninguna ruta queda sin decisión de autorización.	Prueba automática que recorre todas las rutas.
3	Ningún objeto se entrega por adivinar su identificador.	Pruebas de cambio de identificador con cada rol, con OWASP ZAP.
4	La bitácora no se puede alterar sin que se note.	Se modifica un registro en un ambiente de prueba y la verificación de la cadena lo detecta.
5	Sin registro no hay acción.	Con la bitácora deshabilitada, toda operación se rechaza.
6	El sistema niega cuando el motor no responde.	Se detiene el motor y toda petición se deniega.
7	No hay secretos en el código ni en las imágenes.	Análisis del repositorio y de las imágenes sin hallazgos.
8	La configuración de producción es segura.	`check --deploy`, testssl.sh y el análisis de imágenes sin hallazgos altos.
9	Los respaldos sirven.	Restauración completa en un servidor limpio, con la cadena de la bitácora íntegra.
10	Un tercero intentó romperlo.	Prueba de penetración autorizada por escrito, con sus hallazgos altos corregidos.

Dónde está cada respuesta. Para construir no hace falta consultar al equipo de diseño. Esto es lo que el equipo constructor recibe y dónde buscar.

Si la pregunta es…	la respuesta está en…
¿Qué puede hacer cada rol sobre cada objeto?	La matriz (Entregable 3, sección 2).
¿Qué condición tiene un permiso?	Reglas C1 a C20 y H1 a H4 (Entregable 3, sección 3).
¿Cómo sé que una regla quedó bien construida?	Casos T-01 a T-37 (Entregable 3, sección 7).
¿Por qué este modelo, estos controles y esta separación?	Entregable 2, secciones 3, 4 y 5.
¿Qué se registra, por cuánto tiempo y quién lo lee?	Políticas POL-BT (Entregable 1, sección 6.3) y la sección 4.5.
¿Qué contraseña, qué segundo factor y qué sesión?	Políticas POL-AU (Entregable 1, sección 7).
¿Dónde se hospeda y quién lo opera?	Sección 5 y Anexo B.
¿Qué respondió el cliente y qué supuso el equipo?	La minuta (Entregable 1, Anexos A y B) y el Anexo C de este documento.

Anexo A. Diagramas

A.1 Componentes y fronteras de confianza

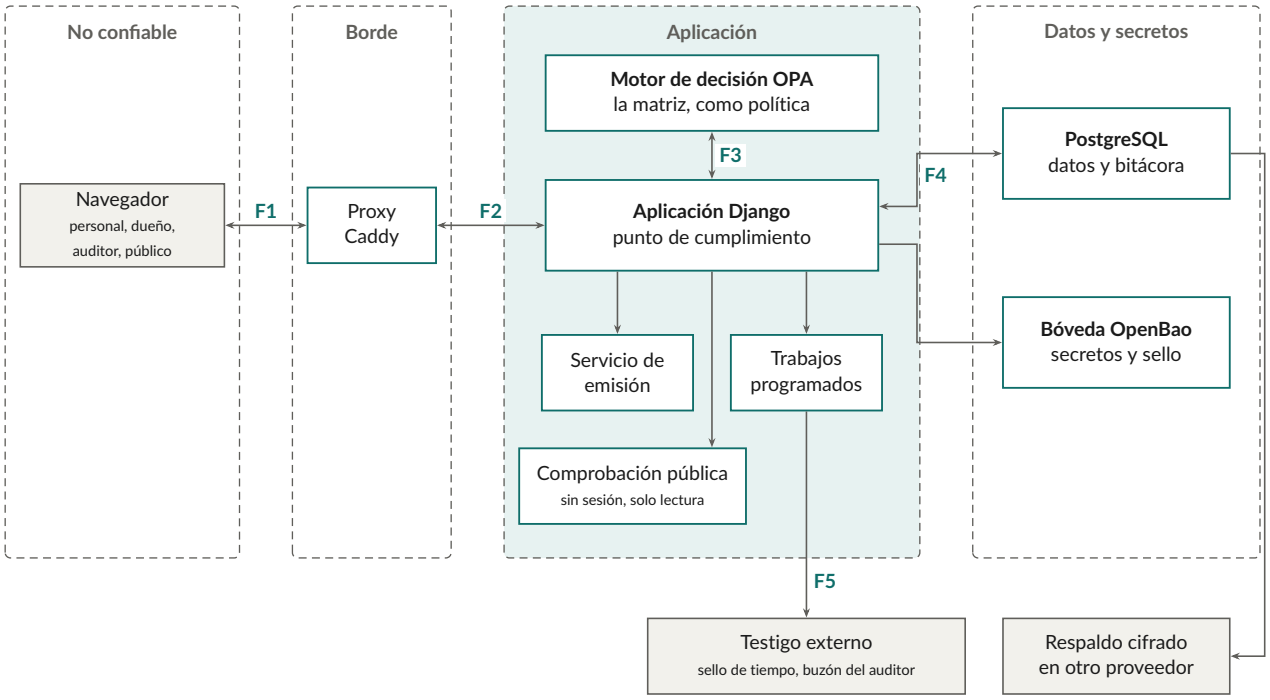
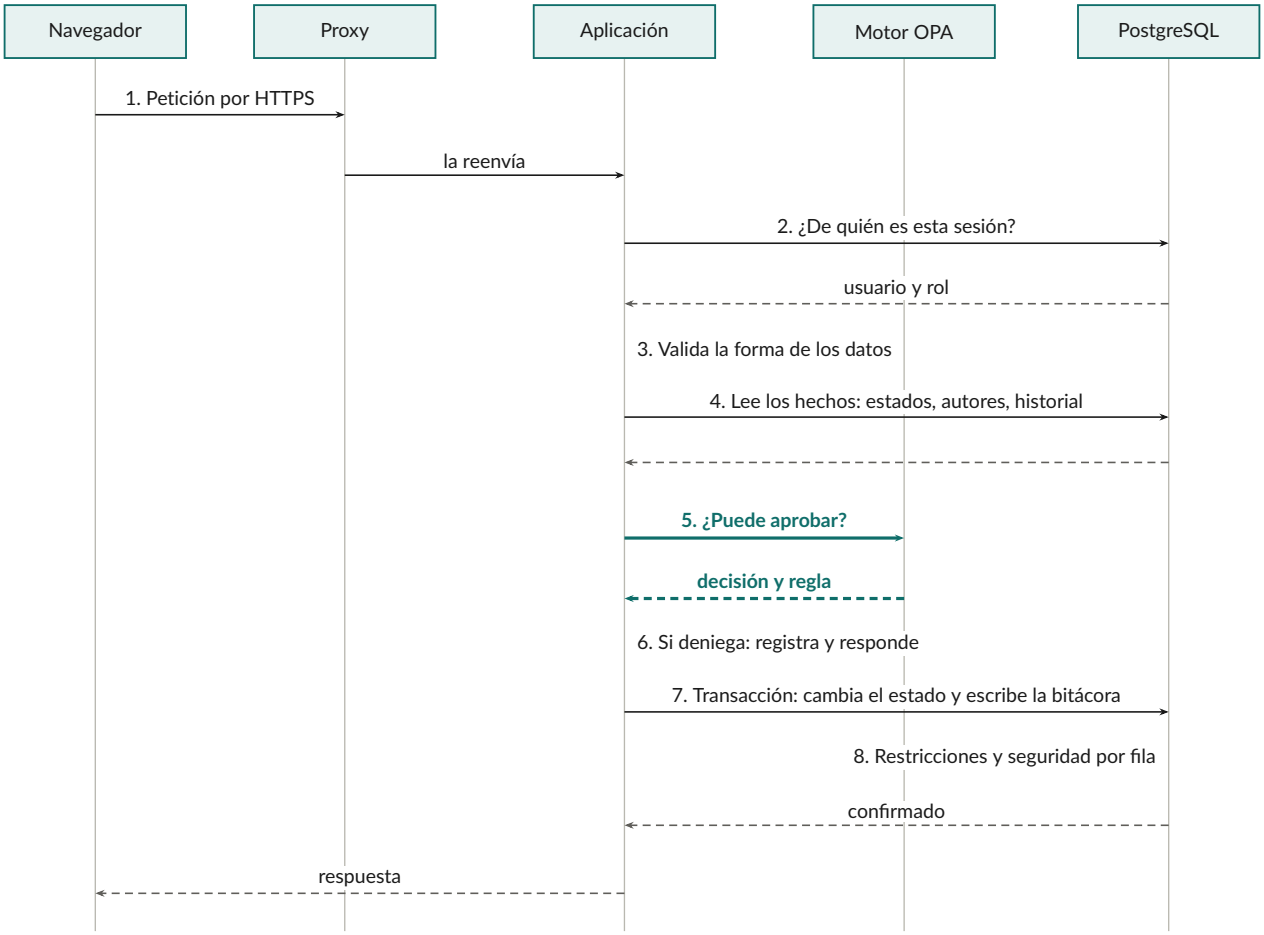


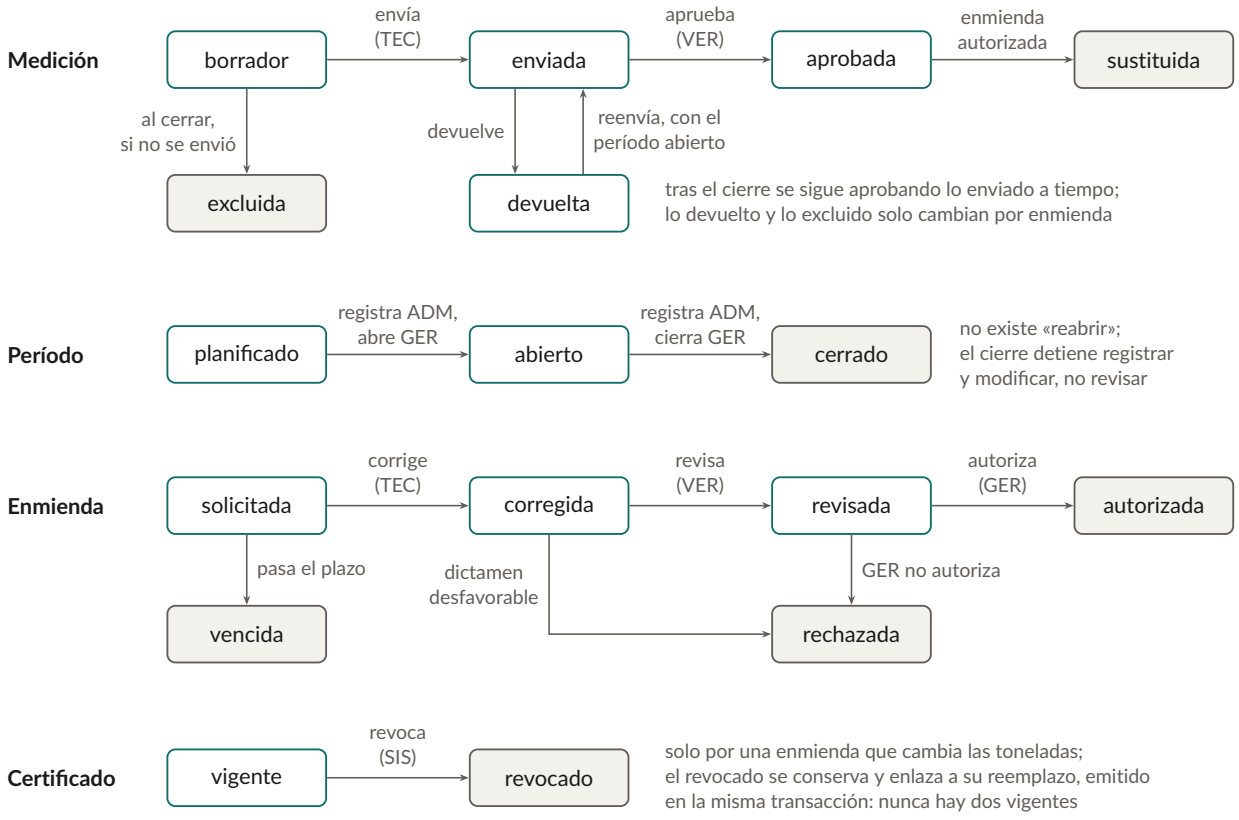
Figura 1: Componentes y fronteras de confianza (F1 a F5). Las líneas punteadas separan las zonas; solo el proxy es alcanzable desde Internet. El servidor es una máquina virtual contratada a un proveedor externo.

A.2 Secuencia de una petición: aprobar una medición



El paso 5, en color, es el único punto donde se concede un permiso. Los pasos 7 y 8 pueden negar, pero nunca conceder.

A.3 Estados de los objetos que condicionan los permisos



A.4 Despliegue en el servidor

Contenedor	Red	Puerto publicado	Notas de endurecimiento
Proxy	Externa e interna	443	El único con salida a Internet entrante.
Aplicación	Interna	Ninguno	Solo lectura; sin sitio de administración.
Motor de decisión	Interna	Ninguno	Política cargada desde un paquete firmado.
Emisión y trabajos	Interna	Ninguno	Identidad propia ante la base y la bóveda.
Comprobación pública	Interna	Ninguno	Sin sesión; solo lee la vista de certificados; límite de ritmo en el proxy.
Base de datos	Interna	Ninguno	Volumen en disco cifrado; cuentas separadas por función.
Bóveda	Interna	Ninguno	Se abre con dos de tres custodios.

Todos corren sin privilegios, confinados por SELinux, con el sistema de archivos de solo lectura y sin capacidades adicionales del núcleo.

Anexo B. Capacidad y operación

B.1 Supuestos de capacidad

El cliente no tiene cifras definitivas y autorizó al equipo a fijar supuestos razonables, siempre que queden documentados. [minuta P-02] Estos son los que se usaron para escoger el tamaño del servidor. Se tomaron con holgura a propósito: ninguna regla de la matriz depende de ellos.

Magnitud	Supuesto	De dónde sale y qué pasa si se supera
Cuentas internas	Hasta 100	Técnicos, verificadores, supervisores, gerencia y administración, con margen para el crecimiento que el cliente anuncia. Los roles no cambian.
Cuentas de dueños y representantes	Hasta 2 000	Una o dos por titular. Solo leen.
Fincas y parcelas	2 000 y 10 000	Cinco parcelas por finca. La restricción de traslape usa un índice espacial y no se degrada con el tamaño.
Períodos por año	Hasta 4	Con 10 000 parcelas son 40 000 mediciones por año, y 400 000 en diez años.
Sesiones simultáneas	Hasta 100	El inicio de sesión es lo más costoso: Argon2id usa 100 MiB por cálculo. Se limita a ocho a la vez.
Registros de bitácora	5 millones por año	100 personas, 200 eventos por día, 250 días. Unos 3 GB por año y 30 GB en diez: cabe en un disco común. La tabla se divide por mes.
Servidor	4 núcleos, 16 GB, 200 GB	Si la carga se duplica, se amplía el mismo servidor virtual sin migrar. Si se multiplica por diez, la base pasa a un segundo servidor; el diseño no cambia.

B.2 Calendario de operación

Frecuencia	Tarea	Quién
Diaria	Respaldo y archivo continuo; parches de seguridad; verificación de la cadena de la bitácora y envío de su huella; vencimiento de cuentas, habilitaciones y asignaciones.	Automático. El operador lee el aviso diario.
Semanal	Resumen de alertas, asignaciones temporales y restricciones levantadas.	Automático, para la Gerencia.
Mensual	Reinicio de mantenimiento y apertura de la bóveda.	El operador y un segundo custodio, con guía paso a paso.
Por período	Revisión de cuentas, roles, asignaciones y declaraciones de vínculos; calibración de umbrales.	La Gerencia, con el reporte que genera el sistema.
Semestral	Prueba de restauración en un servidor limpio.	El operador, con guía.
Anual	Rotación de la llave de sello; activación de las cuentas de auditor.	La Gerencia y los custodios.
Extraordinaria	Cambio de versión mayor, incidente de seguridad, prueba de penetración.	Soporte especializado, por contrato.

Anexo C. Respuestas del cliente y supuestos declarados

La primera versión de este documento se escribió con supuestos de trabajo. El cliente respondió por escrito catorce de las veintiséis consultas del equipo; la minuta completa es el Anexo A del informe de políticas. Estas son las respuestas que tocan la arquitectura.

Consulta	Supuesto original	Lo que respondió el cliente	Qué cambió aquí
P-02	Decenas de usuarios.	No hay cifras; documentar supuestos de capacidad.	Supuestos declarados (sección 1 y Anexo B.1).
P-04	El certificado se sella con una llave de la empresa.	Interesa demostrar autenticidad, estado y quién autorizó; valorar la firma digital.	Sección 4.8; componente de comprobación pública; RR-13.
P-06	Lo no aprobado al cierre queda excluido.	La revisión puede terminar después del cierre.	Estados de la medición y del período (Anexo A.3).
P-07, P-08	La enmienda se autoriza y luego se verifica; el certificado se revoca y se reemite.	Revisión técnica antes de la autorización final; nunca dos certificados vigentes.	Estados de la enmienda y del certificado (Anexo A.3); revocar y emitir en una transacción.
P-15	El diseño no guardaba vínculos.	No existe un registro formal de vínculos entre empleados y dueños.	Datos de la regla C17; RR-11.
P-18	Sin copias para los auditores.	A veces exportan evidencia; acceso en sitio o remoto.	Registro de paquetes exportados (C18).
P-22	El técnico registra en línea.	Señal inestable, registro posterior, equipos distintos; sin aplicación sin conexión.	Sección 4.7; frontera F1; RR-4 y RR-8.
P-23	Un servidor que opera un proveedor; sin llaves físicas.	Hospedaje por decidir; operación por personal designado, sin especialistas; sin presupuesto para llaves.	Sección 5; Anexo B.2; RR-7 y RR-12.

Supuestos que el equipo fijó, porque el cliente no respondió la consulta:

Consulta	Supuesto declarado	Qué cambia si es otro
P-19	Las consultas se conservan dos años; los cambios y decisiones, diez.	La partición y el archivo de la bitácora.
P-21	Una hectárea se identifica por la geometría de su parcela.	La restricción espacial de la regla C11.
P-24	Se tolera un día de interrupción; no se tolera perder datos.	Si no se tolera, hace falta un segundo servidor (RR-6).
P-26	El histórico se migra una vez y queda marcado.	El riesgo RR-9.

Referencias

Adams, C., Cain, P., Pinkas, D., & Zuccherato, R. (2001). *Internet X.509 public key infrastructure time-stamp protocol (TSP)* (RFC 3161). Internet Engineering Task Force. https://doi.org/10.17487/RFC3161

AlmaLinux OS Foundation. (2026). *AlmaLinux 10.2 release notes*. https://wiki.almalinux.org/release-notes/10.2.html

Biryukov, A., Dinu, D., Khovratovich, D., & Josefsson, S. (2021). *Argon2 memory-hard function for password hashing and proof-of-work applications* (RFC 9106). Internet Research Task Force. https://doi.org/10.17487/RFC9106

Django Software Foundation. (2026). *Security in Django* (versión 5.2) [Documentación]. https://docs.djangoproject.com/en/5.2/topics/security/

Hu, V. C., Ferraiolo, D., Kuhn, R., Schnitzer, A., Sandlin, K., Miller, R., & Scarfone, K. (2014). *Guide to attribute based access control (ABAC) definition and considerations* (NIST SP 800-162). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-162

Morris, R., & Thompson, K. (1979). Password security: A case history. *Communications of the ACM, 22*(11), 594–597. https://doi.org/10.1145/359168.359172

Open Policy Agent. (2026). *Open Policy Agent documentation* (versión 1.21) [Documentación]. https://www.openpolicyagent.org/docs/

OpenBao. (2026). *OpenBao documentation* (versión 2.7) [Documentación]. https://openbao.org/docs/

OWASP Foundation. (2023). *OWASP API security top 10: API1:2023 broken object level authorization*. https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/

OWASP Foundation. (s. f.). *Password storage cheat sheet*. OWASP Cheat Sheet Series. Recuperado el 1 de octubre de 2026, de https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

Podman. (2026). *Podman documentation* [Documentación]. https://docs.podman.io/

PostgreSQL Global Development Group. (2026). *PostgreSQL 18 documentation: Row security policies* [Documentación]. https://www.postgresql.org/docs/18/ddl-rowsecurity.html

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278–1308. https://doi.org/10.1109/PROC.1975.9939

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM Transactions on Information and System Security, 2*(2), 159–176. https://doi.org/10.1145/317087.317089

Vargas Rivera, A. (2026). *Material de estudio, clases 2, 10, 12, 13 y 14* [Material de clase]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.